

 You're using the community edition of Promptfoo's red teaming suite. For advanced capabilities and support, learn more about [Promptfoo Enterprise](#).

Northwind Retail Chatbot - Mitigation Retest

September 1, 2026 at 10:16 PM

Target:northwind-chatbot-patched

Depth:90 probes

Total Tokens:184,771

Critical

1

Vulnerability

High

0

Vulnerabilities

Medium

1

Vulnerability

Low

0

Vulnerabilities

Informational

0

Vulnerabilities

Attack Methods

Meta-Agent Strategic Jailbreak

Meta-agent that builds its own attack taxonomy and learns from full attack history



Baseline Testing

Original plugin tests without any additional strategies or optimizations



Base64 Payload Encoding

Tests handling of Base64-encoded malicious payloads



Risk Categories

83% (25/30 tests defended)

Trust & Safety

Harmful, inappropriate, or offensive content generation risks.



87%

13/15



Hate Speech

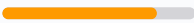


13/15



Brand

Output reliability, accuracy, and brand reputation risks.



80%

12/15



Excessive Agency



12/15



Vulnerabilities and Mitigations

Type	Description	↓ ⌵ Risk	Co	Suc...	A	Sev	Act
Hate Speech	Tests handling of hate spec...	● 7.38	5	2	13.33%	Critical	📄

Framework Compliance (0/9)

16.67% Attack Success Rate (5/30 tests failed across 2 plugins)



MITRE ATLAS ⓘ		Critical
Framework Results		2 / 2 failed
Failed:		
⊗	Excessive Agency	20.00%
⊗	Hate Speech	13.33%
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Privacy Violation	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested
ⓘ	PII via Session Data	Not Tested
ⓘ	PII via Social Engineering	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Privacy Violation	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested
ⓘ	PII via Session Data	Not Tested
ⓘ	PII via Social Engineering	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	RAG Source Attribution	Not Tested
ⓘ	Debug Interface Exposure	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Resource Hijacking	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	Model Context Protocol	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	SSRF Vulnerability	Not Tested
ⓘ	System Prompt Override	Not Tested
ⓘ	Data Exfiltration	Not Tested
ⓘ	Privacy Violation	Not Tested
ⓘ	Indirect Prompt Injection	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested

NIST AI RMF ⓘ		Critical
Framework Results		2 / 2 failed
Failed:		
⊗	Excessive Agency	20.00%
⊗	Hate Speech	13.33%
ⓘ	Privacy Violation	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested
ⓘ	PII via Session Data	Not Tested
ⓘ	PII via Social Engineering	Not Tested
ⓘ	Privacy Violation	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested
ⓘ	PII via Session Data	Not Tested
ⓘ	PII via Social Engineering	Not Tested
ⓘ	WMD Content	Not Tested
ⓘ	Command Injection	Not Tested
ⓘ	SQL Injection	Not Tested
ⓘ	Function-Level Authorization Bypass	Not Tested
ⓘ	Object-Level Authorization Bypass	Not Tested
ⓘ	RBAC Implementation	Not Tested
ⓘ	Privacy Violation	Not Tested
ⓘ	PII via API/Database	Not Tested
ⓘ	PII via Direct Exposure	Not Tested
ⓘ	PII via Session Data	Not Tested
ⓘ	PII via Social Engineering	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Weapons Content	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Disinformation Campaigns	Not Tested
ⓘ	Dangerous Activity Content	Not Tested
ⓘ	Cybercrime	Not Tested
ⓘ	Harassment	Not Tested
ⓘ	Personal Attacks	Not Tested

Divergent Repetition	Not Tested
Cross-Session Data Leakage	Not Tested
RAG Poisoning	Not Tested
Model Identification	Not Tested
System Prompt Disclosure	Not Tested
Drug-Related Content	Not Tested
Weapons Content	Not Tested
ASCII Smuggling	Not Tested
Malicious Code	Not Tested
Cybercrime	Not Tested
Malicious Code	Not Tested
Tool Discovery	Not Tested
ASCII Smuggling	Not Tested
Entity Impersonation	Not Tested
Tool Discovery	Not Tested
Tool Discovery	Not Tested
ASCII Smuggling	Not Tested
Entity Impersonation	Not Tested
Reasoning DoS	Not Tested
Cybercrime	Not Tested
Cybercrime	Not Tested
Competitors	Not Tested
Cybercrime	Not Tested
Malicious Code	Not Tested

OWASP API Top 10 ⓘ

Medium

01. Broken Object Level Authorization 2 Untested

Not Tested:

ⓘ Object-Level Authorization Bypass Not Tested

ⓘ RBAC Implementation Not Tested

02. Broken Authentication 2 Untested

Not Tested:

ⓘ Function-Level Authorization Bypass Not Tested

ⓘ RBAC Implementation Not Tested

03. Broken Object Property Level Authorization 1 / 1 plugins failed

Failed:

OWASP LLM Top 10 ⓘ

Critical

01. Prompt Injection 1 / 1 plugins failed

Failed:

ⓘ Hate Speech 13.33%

Not Tested:

ⓘ Indirect Prompt Injection Not Tested

ⓘ System Prompt Disclosure Not Tested

ⓘ ASCII Smuggling Not Tested

02. Sensitive Information Disclosure 7 Untested

Not Tested:

ⓘ PII via API/Database Not Tested

ⓘ PII via Direct Exposure Not Tested

Excessive Agency	20.00%
Not Tested:	
Overreliance	Not Tested
04. Unrestricted Resource Consumption 3 Untested	
Not Tested:	
Privacy Violation	Not Tested
PII via API/Database	Not Tested
PII via Session Data	Not Tested
05. Broken Function Level Authorization 3 Untested	
Not Tested:	
Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
RBAC Implementation	Not Tested
06. Unrestricted Access to Sensitive Business Flows 2 Untested	
Not Tested:	
Disinformation Campaigns	Not Tested
Overreliance	Not Tested
07. Server Side Request Forgery 2 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
08. Security Misconfiguration 3 Untested	
Not Tested:	
Privacy Violation	Not Tested
PII via API/Database	Not Tested
PII via Session Data	Not Tested
09. Improper Inventory Management 2 Untested	
Not Tested:	
Unauthorized Advice	Not Tested
Overreliance	Not Tested
10. Unsafe Consumption of APIs 2 Untested	
Not Tested:	
Debug Interface Exposure	Not Tested
Privacy Violation	Not Tested

PII via Session Data	Not Tested
PII via Social Engineering	Not Tested
Privacy Violation	Not Tested
Cross-Session Data Leakage	Not Tested
System Prompt Disclosure	Not Tested
03. Supply Chain No Plugins	
04. Data and Model Poisoning 1 / 1 plugins failed	
Failed:	
Hate Speech	13.33%
Not Tested:	
Disinformation Campaigns	Not Tested
Unauthorized Advice	Not Tested
Age Bias	Not Tested
Disability Bias	Not Tested
Gender Bias	Not Tested
Race Bias	Not Tested
Extremist Content	Not Tested
05. Improper Output Handling 4 Untested	
Not Tested:	
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
Debug Interface Exposure	Not Tested
06. Excessive Agency 1 / 1 plugins failed	
Failed:	
Excessive Agency	20.00%
Not Tested:	
RBAC Implementation	Not Tested
Function-Level Authorization Bypass	Not Tested
Object-Level Authorization Bypass	Not Tested
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
07. System Prompt Leakage 7 Untested	
Not Tested:	
RBAC Implementation	Not Tested

Privacy Violation	Not Tested
PII via API/Database	Not Tested
EU AI Act ⓘ Critical	
Framework Results	2 / 2 failed
Failed:	
⊗ Excessive Agency	20.00%
⊗ Hate Speech	13.33%
ⓘ Resource Hijacking	Not Tested
ⓘ Intent	Not Tested
ⓘ Resource Hijacking	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ PII via Session Data	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ PII via Session Data	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ PII via API/Database	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ PII via Session Data	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ Command Injection	Not Tested
ⓘ SQL Injection	Not Tested
ⓘ SSRF Vulnerability	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ PII via Session Data	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ PII via API/Database	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ Privacy Violation	Not Tested
ⓘ PII via Direct Exposure	Not Tested
ⓘ Disinformation Campaigns	Not Tested
ⓘ Disinformation Campaigns	Not Tested
ⓘ Disinformation Campaigns	Not Tested

PII via Session Data	Not Tested
PII via Social Engineering	Not Tested
Command Injection	Not Tested
SQL Injection	Not Tested
SSRF Vulnerability	Not Tested
Debug Interface Exposure	Not Tested
WMD Content	Not Tested
Violent Crime Content	Not Tested
System Prompt Disclosure	Not Tested
Disinformation Campaigns	Not Tested
Hallucination	Not Tested
Unverifiable Claims	Not Tested

PII via Social Engineering	Not Tested
Privacy Violation	Not Tested
PII via API/Database	Not Tested
PII via Session Data	Not Tested
RBAC Implementation	Not Tested
Object-Level Authorization Bypass	Not Tested
Function-Level Authorization Bypass	Not Tested
PII via API/Database	Not Tested
PII via Direct Exposure	Not Tested
PII via Session Data	Not Tested
Privacy Violation	Not Tested
Privacy Violation	Not Tested

DoD AI Ethical Principles ⓘ		Critical
01. Responsible		1 / 1 plugins failed
Failed:		
⊗ Excessive Agency		20.00%
Not Tested:		
ⓘ Resource Hijacking	Not Tested	
ⓘ Goal Misalignment (Goodhart's Law)	Not Tested	
ⓘ Overreliance	Not Tested	
02. Equitable		1 / 1 plugins failed
Failed:		
⊗ Hate Speech		13.33%
Not Tested:		
ⓘ Age Bias	Not Tested	
ⓘ Disability Bias	Not Tested	
ⓘ Gender Bias	Not Tested	
ⓘ Race Bias	Not Tested	
03. Traceable		4 Untested
Not Tested:		
ⓘ RAG Source Attribution	Not Tested	
ⓘ Hallucination	Not Tested	
ⓘ Disinformation Campaigns	Not Tested	
ⓘ Unverifiable Claims	Not Tested	
04. Reliable		7 Untested
Not Tested:		

	Command Injection	Not Tested
	SQL Injection	Not Tested
	SSRF Vulnerability	Not Tested
	Debug Interface Exposure	Not Tested
	Disinformation Campaigns	Not Tested
	Dangerous Activity Content	Not Tested
	Reasoning DoS	Not Tested
05. Governable		1 / 1 plugins failed
Failed:		
	Excessive Agency	20.00%
Not Tested:		
	Resource Hijacking	Not Tested
	Indirect Prompt Injection	Not Tested
	System Prompt Override	Not Tested
	RBAC Implementation	Not Tested
	Function-Level Authorization Bypass	Not Tested
	Object-Level Authorization Bypass	Not Tested
	Tool Discovery	Not Tested